UNIVERSITÉ PARIS 1
PANTHÉON SORBONNE

Sécurité informatique – Responsable : Fabrice

(Session 1, module 5)

S1-isi5-sécurité

Année 2025-2026

Version 0.1

Résumé

Ce cours présente une analyse des principales menaces pesant sur les applications web, en se concentrant sur les attaques par injection SQL (SQLi), les scripts intersites (Cross-Site Scripting - XSS), la falsification de requêtes intersites (Cross-Site Request Forgery - CSRF), ainsi que les techniques de distribution de logiciels malveillants telles que le téléchargement furtif (Drive-by Download) et l'attaque du point d'eau (Watering Hole).

L'injection SQL reste une vulnérabilité critique permettant aux attaquants de manipuler les requêtes de base de données d'une application pour contourner les authentifications, extraire, modifier ou détruire des données sensibles. Le Cross-Site Scripting, quant à lui, consiste à injecter des scripts malveillants côté client dans des pages web consultées par d'autres utilisateurs, menant principalement au vol de sessions et de données. La falsification de requêtes intersites (CSRF) force le navigateur d'un utilisateur authentifié à exécuter des actions indésirables sur un site web, exploitant la confiance que le site accorde à l'utilisateur.

Enfin, les techniques comme le téléchargement furtif et l'attaque du point d'eau illustrent des méthodes d'infection où la simple visite d'un site web compromis peut entraîner l'installation de malwares, la seconde étant une variante ciblée de la première. Bien que des mécanismes de défense robustes existent pour chaque type d'attaque, leur efficacité dépend entièrement d'une mise en œuvre correcte, d'une configuration sécurisée par défaut et d'une sensibilisation continue des développeurs. La persistance de ces failles souligne la nécessité d'une approche de sécurité en profondeur, intégrant des pratiques de codage sécurisées, des configurations de frameworks rigoureuses et des tests de sécurité continus.

Introduction à la Cybersécurité

Qu'est-ce que la Cybersécurité ?

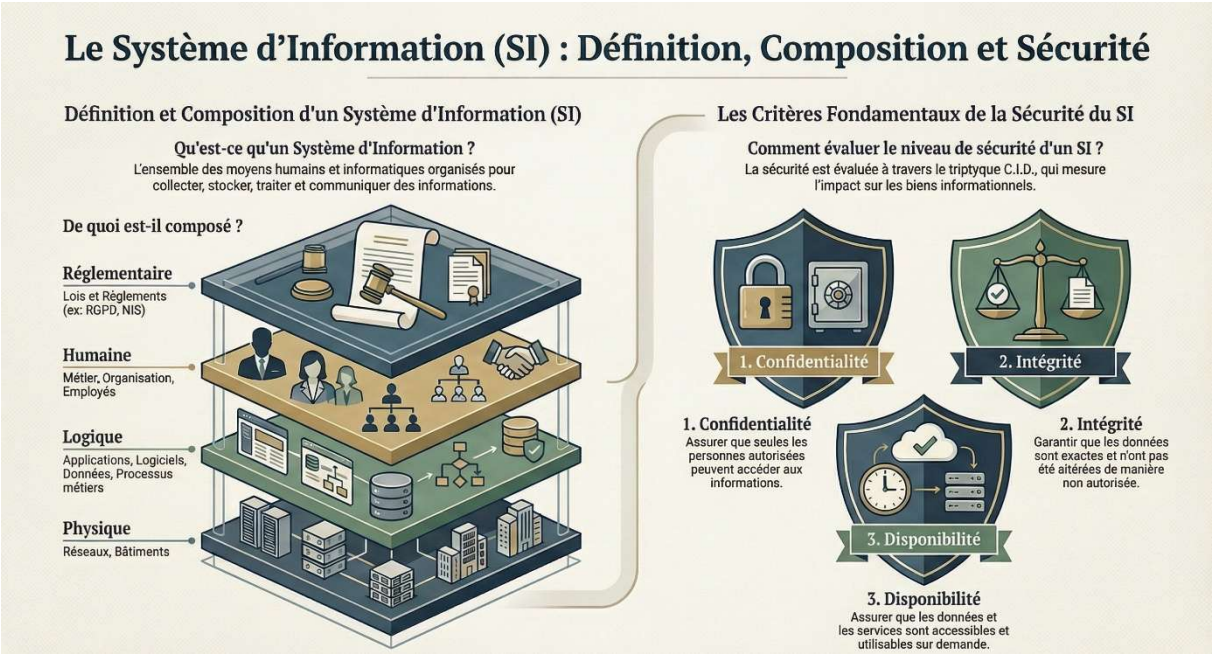
La cybersécurité est la pratique visant à protéger les systèmes informatiques, les réseaux et les données contre les attaques numériques. Son objectif principal est de garantir que la sécurité de l'ensemble des systèmes d'information soit **globale et cohérente**, en s'assurant que les données, les processus métiers et les technologies sont sécurisés de manière exhaustive.

1 Définition et Composition du Système d'Information (Vision Cyberdéfense)

1.1 Définition du Système d'Information

Le système d'information (SI) est le véhicule de la communication au sein d'une organisation. Il ne se limite pas à l'informatique pure, mais représente l'ensemble des moyens techniques (matériels et logiciels) et humains organisés pour collecter, stocker, traiter et communiquer des informations.

Dans une perspective de cyberdéfense, le SI n'est pas seulement un outil de production, mais un actif critique qu'il faut protéger contre des menaces visant à compromettre ses fonctions essentielles. La sécurité de ces systèmes doit être globale et cohérente pour assurer la pérennité de l'organisation.



Le système d'information et ces composants

Les Critères de Sécurité du SI (Le triptyque CID)

Pour évaluer le niveau de sécurité d'un SI, on s'appuie sur trois critères fondamentaux, souvent appelés le triptyque CID :

- **Confidentialité :** Garantir que l'information n'est accessible qu'aux personnes autorisées. Le chiffrement est une mesure clé pour assurer cette confidentialité, rendant les données illisibles sans clé.
- **Intégrité :** Assurer que les données n'ont pas été modifiées ou détruites de manière non autorisée. Le hachage cryptographique est souvent utilisé pour valider cette intégrité.
- **Disponibilité :** Garantir que le système et les données sont accessibles lorsque les utilisateurs en ont besoin. Les attaques par déni de service (DDoS) visent spécifiquement à compromettre ce critère.

Au-delà de ces critères, la notion de **cyberrésilience** est cruciale. Elle décrit la capacité d'une organisation à maintenir ses processus essentiels malgré des incidents, à limiter les dommages et à revenir rapidement à un fonctionnement normal.

3 Composition du Système d'Information et Surfaces d'Attaque

La vision cyberdéfense impose de décomposer le SI en "objets à protéger" afin d'identifier les vecteurs d'attaque potentiels.

La Couche Physique et Matérielle (Endpoints et Infrastructures)

Cette couche comprend les actifs tangibles qui peuvent être ciblés ou utilisés comme vecteurs d'entrée.

- **Postes de travail et terminaux mobiles :** Ils constituent souvent la "tête de pont" vers le réseau et le cloud pour les attaquants. L'utilisation d'équipements personnels (BYOD - Bring Your Own Device) élargit cette surface d'attaque.
- **Serveurs et Datacenters :** Ils hébergent les applications et les données critiques.
- **Technologies Opérationnelles (OT) et IoT :** Dans le secteur industriel, cela inclut les automates programmables (PLC) et les systèmes SCADA. Ces équipements, souvent peu sécurisés par conception, sont désormais interconnectés avec l'IT, créant de nouveaux risques (ex: ransomware EKANS/SNAKE).
- **Périphériques :** Les clés USB ou autres supports amovibles peuvent être des vecteurs d'infection virale.

La Couche Réseau et Communication

Elle assure l'interconnexion des composants et est le théâtre de nombreuses attaques (sniffing, Man-in-the-Middle).

- **Protocoles de communication :** Certains protocoles anciens comme le SMBv1 sont vulnérables et doivent être désactivés au profit de versions sécurisées. Le protocole ARP, utilisé pour lier adresses IP et MAC, est vulnérable à l'usurpation (ARP Spoofing) permettant l'interception de trafic.
- **Services exposés :** Les services accessibles depuis Internet, tels que le RDP (Remote Desktop Protocol) ou les VPN, sont des vecteurs d'accès initial fréquents pour les attaquants s'ils sont mal configurés ou non corrigés.
- **Infrastructure DNS :** Le système de noms de domaine est critique. Il peut être la cible d'attaques par amplification pour provoquer des dénis de service (DDoS) ou d'attaques par usurpation (DNS Spoofing) pour rediriger le trafic.

La Couche Applicative et Logicielle

Les failles dans les logiciels permettent aux attaquants de manipuler les bases de données ou d'exécuter du code malveillant.

- **Applications Web :** Elles sont vulnérables aux injections SQL (permettant de manipuler la base de données), aux attaques XSS (Cross-Site Scripting) qui exécutent des scripts dans le navigateur de l'utilisateur, et aux attaques CSRF (Cross-Site Request Forgery) qui forcent un utilisateur à exécuter des actions non voulues.
- **Systèmes d'exploitation et Virtualisation :** Les hyperviseurs (comme VMware ESXi) doivent être durcis car ils sont des cibles pour le chiffrement de masse par ransomware.
- **Vulnérabilités logicielles :** Les logiciels non mis à jour (patch management défaillant) offrent des portes d'entrée via des exploits connus (ex: vulnérabilités CVE).

La Couche des Données

La donnée est l'actif le plus précieux, visé par le vol (exfiltration) ou le chiffrement (ransomware).

- **Données sensibles :** Propriété intellectuelle, données clients (PII), données financières.
- **Sauvegardes :** Elles sont la cible prioritaire des ransomwares pour empêcher la récupération.

La couche Humaine et Organisationnelle

Souvent considérée comme le maillon faible, cette couche est pourtant essentielle à la détection et à la résilience.

- **Utilisateurs :** Ils sont la cible de l'ingénierie sociale (phishing, fraude au président). Un employé mécontent ou corrompu représente également une menace interne ("insider threat").
- **Chaîne d'approvisionnement (Supply Chain) :** Les fournisseurs de services gérés (MSP) et les tiers interconnectés au SI constituent des vecteurs d'infection indirects majeurs.
- **Administration :** Les comptes à privilèges (administrateurs) sont des cibles prioritaires. Leur compromission permet aux attaquants de se déplacer latéralement dans le réseau.

Architecture de Défense du SI

Pour protéger cette composition complexe, une architecture de défense en profondeur est nécessaire :

- **Segmentation Réseau :** Diviser le réseau en sous-réseaux (VLAN) pour limiter les mouvements latéraux des attaquants et contenir les incidents comme les ransomwares.
- **Architecture Zero Trust :** Ne jamais faire confiance par défaut, vérifier systématiquement l'identité et l'intégrité des appareils, et appliquer le principe de moindre privilège.
- **Gestion des Identités et des Accès (IAM) :** Utiliser l'authentification multifacteur (MFA) résistante au phishing pour tous les services.
- **Surveillance et Journalisation :** Collecter et analyser les journaux (logs) des réseaux, hôtes et services cloud pour détecter les anomalies et répondre aux incidents.

Le Paysage des Menaces Modernes

Le monde numérique est peuplé d'acteurs malveillants aux motivations et capacités variées. Les menaces évoluent constamment, devenant non seulement plus sophistiquées, mais aussi plus industrialisées. L'écosystème cybercriminel est marqué par une professionnalisation et une spécialisation croissante, où les outils d'attaque sont créés plus rapidement que les défenses ne sont mises à jour.

Qui sont les attaquants ?

Les profils des attaquants sont divers, chacun ayant des objectifs spécifiques. Comprendre leurs motivations est la première étape pour anticiper leurs actions.

Profil de l'attaquant	Motivation Principale
Gouvernements	Espionnage étatique, déstabilisation, sabotage d'infrastructures.
Cybercriminels organisés	Gain financier (rançongiciel, fraude), vol de données à des fins lucratives.
Activistes (Hacktivistes)	Revendication idéologique, déstabilisation politique ou sociale.
Cyber terroristes	Sabotage, perturbation d'infrastructures critiques pour semer la terreur.
Script Kiddies	Défi technique, reconnaissance, vandalisme numérique sans motivation financière ou idéologique profonde.
Menaces internes (Employés)	Négligence (erreurs non intentionnelles), sabotage ou vol de données pour des raisons personnelles ou financières.

2.2 L'Évolution de la Cybercriminalité

La cybercriminalité s'est professionnalisée pour devenir une véritable industrie souterraine. Trois tendances clés illustrent cette transformation :

- **Ransomware-as-a-Service (RaaS) :** Ce modèle économique illégal permet aux développeurs de rançongiciels de louer leurs outils malveillants à des "affiliés". Ces derniers, même avec

des compétences techniques limitées, peuvent lancer des attaques en échange d'un pourcentage de la rançon (souvent 20 à 40 %). Cela abaisse considérablement la barrière à l'entrée et multiplie le nombre d'attaques.

- **L'IA comme arme :** L'intelligence artificielle (GenAI) est devenue un outil puissant pour les attaquants. Elle est utilisée pour :
    - Générer des e-mails de *spear-phishing* (hameçonnage ciblé) ultra-crédibles, sans fautes et avec un style naturel.
    - Créer des *deepfakes* audio et vidéo pour usurper l'identité de dirigeants et tromper les employés.
    - Produire rapidement du code malveillant multi-plateformes (Windows, Linux, macOS), rendant la détection plus complexe.
- **La "chasse au gros gibier" ("Big-Game hunting") :** Les attaquants ciblent de plus en plus de grandes organisations (entreprises, hôpitaux, administrations) pour maximiser leurs gains financiers. En paralysant une cible de grande valeur, ils peuvent exiger des rançons beaucoup plus élevées.

Maintenant que nous comprenons qui sont les attaquants et comment ils évoluent, examinons les techniques spécifiques qu'ils déploient pour atteindre leurs cibles.

Les Types d'Attaques Courantes

Les attaquants utilisent un large éventail de techniques, allant de la manipulation psychologique à l'exploitation de failles logicielles complexes.

Manipulation et Tromperie : L'Ingénierie Sociale

L'ingénierie sociale est l'art de la **manipulation psychologique à des fins d'escroquerie**. Plutôt que de pirater un système, l'attaquant pirate un humain en exploitant ses biais cognitifs (confiance, peur, curiosité).

- **Hameçonnage (Phishing) :** C'est une tentative de vol d'informations sensibles (identifiants, mots de passe, données bancaires) par le biais de communications frauduleuses, comme des e-mails, se faisant passer pour des entités de confiance (banque, administration, service en ligne). Une variante plus dangereuse, le ***spear phishing***, est une attaque ultra-ciblée qui utilise des informations personnelles sur la victime pour rendre le message encore plus crédible.
- **Usurpation d'identité (Spoofing) :** Le spoofing consiste à falsifier une identité numérique pour tromper la victime et gagner sa confiance.
    - **Email Spoofing :** L'attaquant falsifie l'en-tête d'un e-mail pour qu'il semble provenir d'un expéditeur légitime (par exemple, votre patron ou votre banque).
    - **DNS Spoofing :** Aussi appelé empoisonnement de cache DNS, cette technique corrompt les enregistrements DNS d'un serveur pour rediriger un utilisateur vers un site web malveillant, même s'il a tapé l'adresse correcte dans son navigateur.
    - **Caller ID Spoofing :** L'attaquant falsifie le numéro de téléphone affiché lors d'un appel. Cette technique est souvent utilisée dans les arnaques au faux conseiller bancaire pour se faire passer pour votre banque.

Attaques sur les Applications Web

De nombreuses attaques exploitent les vulnérabilités présentes dans le code des sites et applications web pour accéder à des informations ou en prendre le contrôle.

- **Injection SQL (SQLi) :** Un attaquant insère des commandes SQL malveillantes dans les champs d'un formulaire web (comme une barre de recherche ou un champ de connexion). Si l'application est mal conçue, ces commandes sont exécutées par la base de données, permettant à l'attaquant de contourner une authentification (avec une commande comme ' OR 1=1 --) ou d'extraire des données sensibles.
- **Cross-Site Scripting (XSS) :** Cette attaque consiste à injecter du code malveillant, généralement du JavaScript, dans une page web consultée par d'autres utilisateurs.
    - **XSS Réfléchi (Reflected) :** Le script malveillant est inclus dans une URL ou un paramètre. Lorsqu'une victime clique sur ce lien, le script s'exécute dans son navigateur, souvent pour voler son cookie de session.
    - **XSS Stocké (Stored) :** Le script malveillant est sauvegardé de manière permanente sur le serveur (par exemple, dans la section des commentaires d'un blog). Il s'exécute alors dans le navigateur de chaque utilisateur qui consulte la page infectée.

Attaques de Perturbation et d'Extorsion

Ces attaques visent à rendre un service indisponible pour ses utilisateurs légitimes ou à extorquer de l'argent sous la menace.

- **Rançongiciel (Ransomware) :** Un rançongiciel est un logiciel malveillant qui **chiffre les fichiers** d'une victime, les rendant inaccessibles. Les attaquants exigent ensuite une rançon, généralement en cryptomonnaie, en échange de la clé de déchiffrement. Les tactiques ont évolué :

    - **Double Extorsion :** Avant de chiffrer les données, les attaquants les **exfiltrent** (volent). Ils menacent ensuite de publier ces données sensibles si la rançon n'est pas payée, ajoutant une pression supplémentaire.
    - **Triple Extorsion :** En plus du chiffrement et de la menace de publication, les attaquants menacent de lancer une attaque par déni de service (DDoS) contre l'infrastructure de la victime pour paralyser son activité.
- Attaques par Déni de Service (DoS et DDoS) :
    - **Définition :** Une attaque par Déni de Service (DoS) vise à rendre un serveur, un service ou une infrastructure indisponible en le submergeant de trafic ou de requêtes. La version **Distribuée** (DDoS) est bien plus puissante, car elle utilise un réseau de machines compromises (*botnet*) pour lancer l'attaque depuis des milliers, voire des millions, de sources simultanément.
    - **Techniques Clés :** Les botnets sont souvent constitués d'ordinateurs, de serveurs ou d'objets connectés (IoT) infectés. Le botnet **Mirai**, par exemple, a démontré la puissance destructrice des objets connectés mal sécurisés (caméras, routeurs) en les utilisant pour lancer des attaques DDoS massives.

Face à un tel éventail de menaces, il est impératif d'adopter des stratégies de défense structurées et robustes.

4. Stratégies de Défense Fondamentales

Une bonne stratégie de cybersécurité ne se résume pas à un seul outil. Elle repose sur des principes directeurs forts et des mesures concrètes, appliquées de manière continue.

Les Principes Clés de la Défense

Ces approches stratégiques constituent le socle d'une posture de sécurité résiliente.

1. **Défense en Profondeur :** Ce concept consiste à mettre en place plusieurs barrières de sécurité successives. L'idée est que si une barrière est franchie par un attaquant, d'autres sont là pour le détecter, le ralentir ou l'arrêter. Chaque couche de défense (pare-feu, antivirus, segmentation réseau, etc.) renforce la sécurité globale.
2. **Principe du Moindre Privilège :** Ce principe dicte que chaque utilisateur, appareil ou application ne doit disposer que des accès et des permissions strictement nécessaires pour accomplir ses tâches légitimes, et rien de plus. Cela limite considérablement les dégâts en cas de compromission d'un compte ou d'un système.
3. **Architecture "Zero Trust" (Confiance Zéro) :** Ce modèle de sécurité moderne part du principe qu'aucune confiance n'est accordée par défaut, que ce soit à l'intérieur ou à l'extérieur du réseau. Chaque demande d'accès, chaque connexion est systématiquement vérifiée, authentifiée et autorisée de manière granulaire, selon le principe : *"Ne jamais faire confiance, toujours vérifier"*.

Les Mesures d'Hygiène Informatique Essentielles

Au-delà des grands principes, des actions concrètes et régulières sont indispensables pour maintenir un niveau de sécurité adéquat.

- **Mises à jour et correctifs (Patch Management) :** Appliquer systématiquement et rapidement les mises à jour des logiciels, des applications et des systèmes d'exploitation. Celles-ci corrigent les vulnérabilités connues que les attaquants cherchent activement à exploiter.
- **Sauvegardes Régulières :** Maintenir des sauvegardes de toutes les données critiques. Ces sauvegardes doivent être **chiffrées, stockées hors ligne** (déconnectées du réseau principal) et testées périodiquement pour garantir leur intégrité et leur fonctionnalité en cas de restauration.
- **Authentification Multi-Facteurs (MFA) :** Ajouter une couche de sécurité cruciale à l'authentification. Le MFA exige au moins un second facteur de vérification (ex: un code depuis une application mobile, une clé physique) en plus du mot de passe, ce qui rend la compromission d'un compte beaucoup plus difficile.
- **Gestion des Mots de Passe :** Imposer l'utilisation de mots de passe longs, uniques pour chaque service et complexes. L'utilisation d'un **gestionnaire de mots de passe** est fortement recommandée. Pour le stockage, les mots de passe doivent toujours être "hachés avec salage" (ajout d'une valeur aléatoire avant le hachage) pour les protéger contre les attaques par tables précalculées (Rainbow Tables).
- **Segmentation du Réseau :** Diviser le réseau en sous-réseaux isolés (segments). Si un attaquant compromet un segment, cette isolation l'empêchera de se propager facilement à d'autres parties du réseau ("mouvement latéral").
- **Sécurisation des E-mails :** Mettre en place les protocoles **SPF, DKIM et DMARC**. Ces trois normes techniques permettent de vérifier l'authenticité des e-mails et de se protéger efficacement contre l'usurpation d'identité par e-mail (email spoofing).
- **Sensibilisation et Formation :** Le maillon humain est souvent la première cible. Éduquer et former régulièrement les utilisateurs à reconnaître les tentatives de phishing, les techniques d'ingénierie sociale et les bonnes pratiques de sécurité est une des défenses les plus efficaces.

Malgré toutes les mesures de prévention, un incident peut toujours survenir. Il est donc crucial de se préparer à y réagir de manière structurée.

Comment Réagir en Cas d'Incident ?

La rapidité et l'efficacité de la réaction sont déterminantes pour limiter l'impact d'une cyberattaque. Avoir un **Plan de Réponse à Incident (IRP)** formalisé et testé est donc crucial. Voici les étapes clés à suivre en cas d'une attaque par rançongiciel :

1. Détection et Analyse

La première étape consiste à confirmer la nature de l'incident et à en évaluer l'étendue.

- **Identifier les signaux :** Repérer les premiers signes de l'attaque, comme des fichiers chiffrés, des extensions de fichiers inhabituelles, des notes de rançon apparaissant sur les écrans ou des systèmes soudainement inaccessibles.
- **Lancer la recherche de menaces (Threat Hunting) :** En parallèle, les équipes techniques doivent immédiatement rechercher des indicateurs de compromission plus profonds. Les attaquants laissent souvent des traces avant de déclencher le chiffrement. Il faut chercher activement :

    - La création de nouveaux comptes dans l'Active Directory ou une élévation de privilèges inattendue sur des comptes existants.
    - L'utilisation anormale d'outils Windows légitimes comme vssadmin.exe (pour supprimer les clichés instantanés/shadow copies), bcdedit.exe ou wbadmin.exe pour entraver la restauration du système.
    - Des signes de présence d'outils de post-exploitation comme Cobalt Strike ou une utilisation suspecte de PowerShell et de la suite PsTools.
    - Des signes d'exfiltration de données, tels qu'un volume de trafic sortant anormalement élevé ou l'utilisation d'outils de synchronisation comme Rclone.
    - Des traces de vol d'identifiants, notamment via l'utilisation d'outils comme Mimikatz ou des commandes comme NTDSutil.exe.

2. Contenir l'Incident

L'objectif est d'empêcher la propagation de l'attaque. L'isolation est la priorité absolue.

- **Isoler les systèmes affectés :** Déconnectez immédiatement les appareils infectés du réseau (Wi-Fi, Ethernet). Cette action doit être rapide et décisive.
- **Identifier la source de l'infection :** Sur les serveurs de fichiers, examinez les sessions actives (Gestion de l'ordinateur > Sessions et Fichiers ouverts) pour identifier quel compte ou quelle machine est en train de chiffrer activement les données.
- **Couper l'accès externe de l'attaquant :** L'isolement ne concerne pas que les postes de travail. Désactivez les VPN, les serveurs d'accès distant (RDP) et les autres ressources exposées sur Internet pour empêcher l'attaquant de maintenir son accès.

3. Éradiquer la Menace

Une fois l'incident contenu, la menace doit être complètement éliminée.

- **Supprimer le maliciel :** Identifiez et supprimez le logiciel malveillant de tous les systèmes affectés.
- **Reconstruire les systèmes :** Dans la plupart des cas, la solution la plus sûre est de réinstaller complètement les systèmes à partir d'images saines et de s'assurer que la vulnérabilité initiale (la porte d'entrée) a été corrigée. Ne restaurez jamais un système sans avoir compris et colmaté la brèche.

4. Récupérer les Données

La restauration des activités doit être méthodique.

- **Restaurer à partir des sauvegardes :** Restaurez les données à partir de sauvegardes **saines, testées et stockées hors ligne**. Priorisez la restauration des services critiques pour l'entreprise afin de reprendre l'activité le plus vite possible.
- **Vérifier l'intégrité :** Avant de reconnecter un système restauré au réseau de production, assurez-vous qu'il est totalement propre et à jour.

5. Tirer les Leçons (Post-Incident)

Chaque incident est une opportunité d'amélioration.

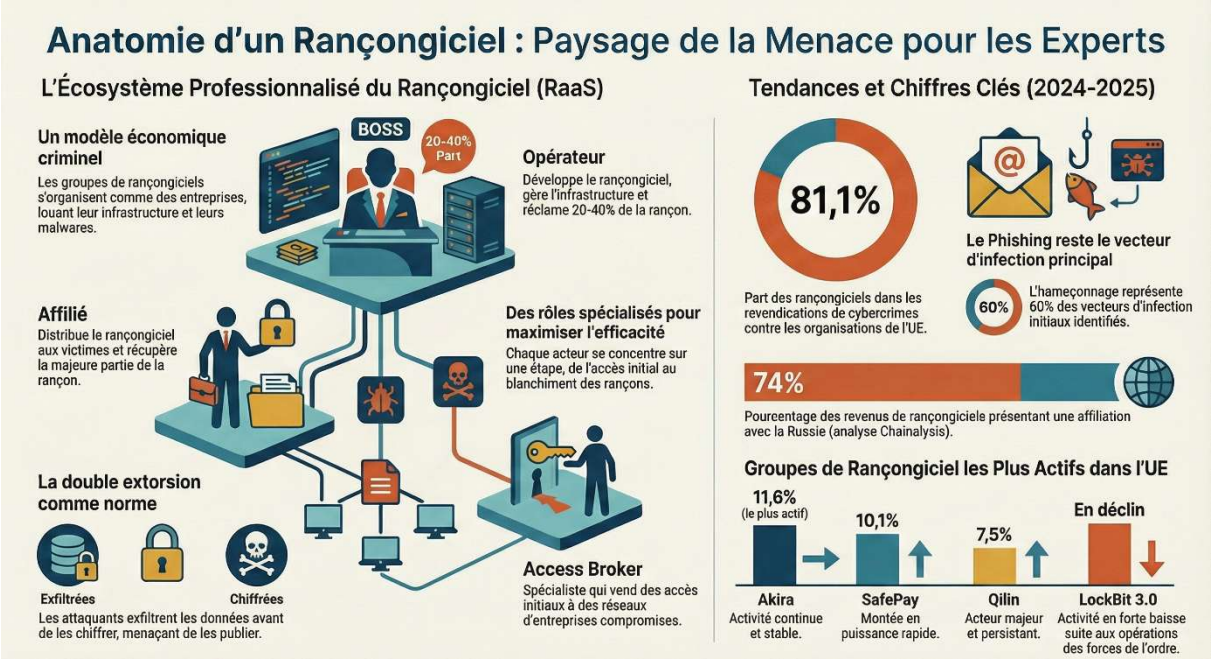
- **Analyser la cause racine :** Menez une analyse post-mortem pour comprendre précisément comment l'attaquant a pu pénétrer et se déplacer dans le système.

- **Documenter et améliorer :** Rédigez un rapport détaillé sur l'incident, les actions menées et les leçons apprises. Utilisez ces informations pour renforcer les défenses, mettre à jour les politiques de sécurité et améliorer le plan de réponse à incident.

Ransomware – Stratégie, Défense et Gestion de Crise

L'État de la Menace 2024-2025 et l'Écosystème Criminel

Ce chapitre analyse la mutation du ransomware d'un simple logiciel malveillant vers une économie de service structurée.

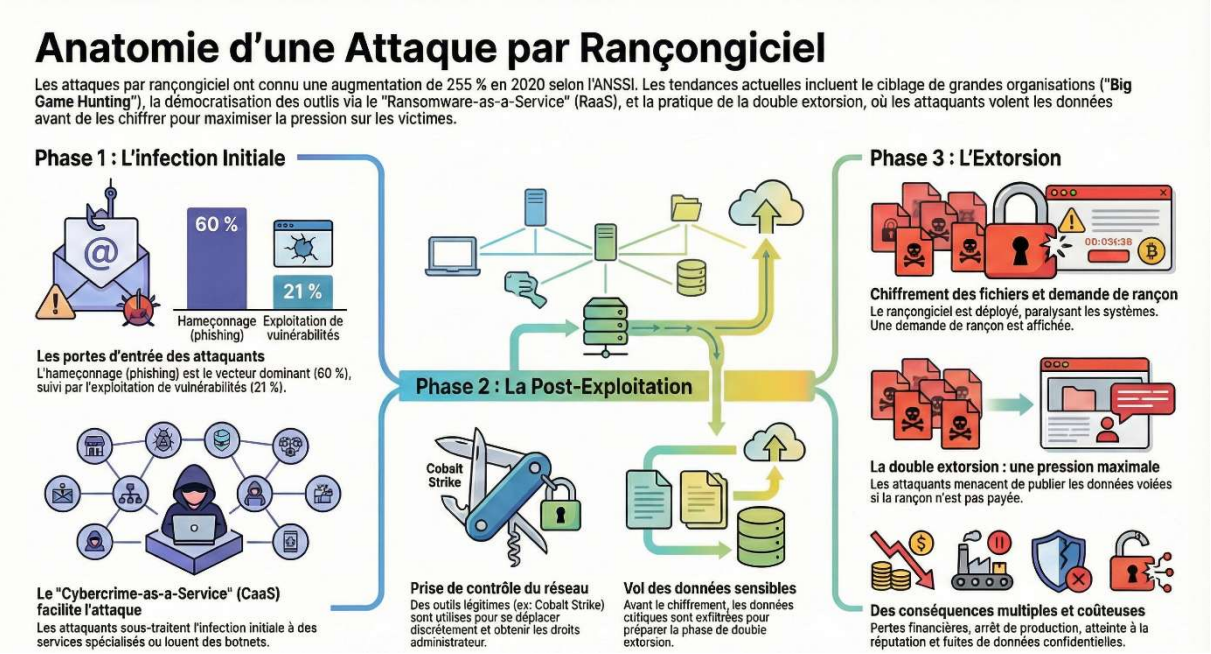


L'industrialisation : Le modèle RaaS (Ransomware-as-a-Service)

- **Structure économique :** Étude de la dissociation entre les **Opérateurs** (développeurs du malware) et les **Affiliés** (qui mènent l'attaque et touchent jusqu'à 80% de la rançon).
- **Acteurs dominants 2024/2025 :** Analyse des groupes les plus actifs comme **RansomHub**, **LockBit 3.0**, **Akira**, **Play**, et **Black Basta**.
- **Initial Access Brokers (IAB) :** Le rôle des courtiers qui vendent des accès "clés en main" (VPN compromis, identifiants RDP) aux groupes de ransomware, réduisant le temps de préparation des attaques.

Évolution des tactiques d'extorsion

- **Double Extorsion :** Exfiltration des données avant chiffrement pour faire chanter la victime sur la divulgation (Leak Sites).
- **Triple Extorsion :** Ajout d'une pression supplémentaire via des attaques DDoS simultanées ou le harcèlement direct des clients/partenaires de la victime pour forcer le paiement.
- **Extorsion sans chiffrement :** Tendance émergente où les attaquants se contentent de voler les données pour extorquer, sans déployer de chiffrement, pour éviter la détection et accélérer l'attaque.



L'impact de l'Intelligence Artificielle

- **IA Offensive :** Utilisation de l'IA pour générer des courriels de phishing hyper-réalistes, des deepfakes pour l'ingénierie sociale (vishing), et pour accélérer le développement de malwares.

Analyse Technique et Vecteurs d'Attaque (Kill Chain)

Comprendre comment l'attaquant pénètre et se déplace, en utilisant les cadres Cyber Kill Chain et MITRE ATT&CK.

Vecteurs d'accès initial (Initial Access)

- **Phishing et Ingénierie Sociale :** Toujours le vecteur dominant (60% des cas selon l'ENISA). Techniques de *Quishing* (QR Code phishing) et *ClickFix*.
- **Exploitation des vulnérabilités (CVE) :** Ciblage des équipements de périphérie (VPN, Firewalls Fortinet/Citrix, serveurs Exchange) souvent non patchés (ex: vulnérabilités "Zero-day" ou "N-day").
- **Identifiants compromis :** Achat d'accès RDP ou VPN sur le dark web.

Post-Exploitation et Mouvements Latéraux

- **Living off the Land (LotL) :** Utilisation d'outils légitimes (PowerShell, WMI, PsExec, RDP) pour éviter la détection par les antivirus traditionnels.
- **Outils offensifs :** Usage de Cobalt Strike, Mimikatz (vol d'identifiants), et d'outils "EDR Killers" pour désactiver les défenses.
- **Active Directory :** La compromission de l'AD est souvent l'objectif central pour obtenir les privilèges "Domain Admin" et déployer le ransomware massivement via GPO.

Architecture de Défense et Prévention

Comment construire un SI résilient capable de résister ou de récupérer rapidement (Cyber-résilience).

Architecture Zero Trust et Segmentation

- **Principes Zero Trust :** "Ne jamais faire confiance, toujours vérifier". Mise en place de l'authentification multifacteur (MFA) résistante au phishing pour tous les accès distants et comptes à privilèges.
- **Segmentation Réseau :** Cloisonnement des réseaux (IT/OT, zones critiques, sauvegardes) pour empêcher la propagation latérale (blast radius).

Stratégie de Sauvegarde Robuste

- **Règle 3-2-1-1 :** 3 copies des données, 2 supports différents, 1 hors site, **1 copie immuable ou hors ligne (déconnectée)**. Les attaquants visent spécifiquement à détruire les sauvegardes en ligne avant de chiffrer.
- **Tests de restauration :** L'importance critique de tester régulièrement la capacité à restaurer les données à partir des sauvegardes.

Hygiène et Durcissement (Hardening)

- **Gestion des correctifs (Patch Management) :** Priorisation des correctifs sur les actifs exposés à Internet (KEV - Known Exploited Vulnerabilities).
- **Désactivation des services inutiles :** PowerShell, macros Office, RDP exposé sur Internet.

Gestion de Crise et Réponse à Incident (CSIRT)

Pilotage opérationnel et stratégique de la crise selon les doctrines ANSSI et CISA.

Le processus de réponse (CISA/NIST)

1. **Préparation :** Plans de réponse (IRP), outillage, annuaires de crise.
2. **Détection & Analyse :** Identification de l'incident, triage, qualification (Anomalie vs Crise Cyber).
3. **Endiguement (Containment) :** Isolation immédiate des systèmes infectés (coupure réseau, extinction si nécessaire) pour stopper la propagation.

4. **Éradication & Rétablissement :** Suppression des malwares, réinitialisation des mots de passe (Krbtgt), reconstruction des systèmes sains (Cœur de confiance).
5. **Post-Incident :** Retours d'expérience (RETEX) et amélioration continue.

La doctrine E3R (ANSSI)

Focus sur la méthode spécifique française : **E**ndiguement, **É**viction de l'attaquant, **É**radication, **R**emédiation. L'objectif est de reprendre le contrôle du SI avant de relancer les services.

Communication de crise

- **Interne :** Informer les collaborateurs, utiliser des canaux de secours (hors bande).
- **Externe :** Gestion de la réputation, communication avec les clients/partenaires, et notification aux régulateurs.

Cadre Juridique, Normatif et Conformité

Les obligations légales qui pèsent sur le RSSI et l'entreprise en 2025.

Réglementations Européennes et Françaises

- **Directive NIS 2 :** Nouvelles obligations pour les entités essentielles et importantes (gestion des risques, notification d'incidents sous 24h/72h, responsabilité de la direction).
- **Loi LOPMI (France) :** Obligation de **dépôt de plainte sous 72h** pour pouvoir être indemnisé par son cyber-assureur.
- **RGPD :** Notification à la CNIL sous 72h en cas de violation de données personnelles.

Le dilemme du paiement de la rançon

- **Position officielle :** L'ANSSI et le FBI recommandent de ne **jamais payer**. Le paiement ne garantit pas la récupération (outil de déchiffrement défaillant) et finance le crime.
- **Risques de Sanctions (OFAC) :** Risques juridiques liés au paiement à des entités sous sanctions internationales (ex: groupes liés à la Russie ou la Corée du Nord).

Normes de gestion des risques

- **ISO/IEC 27005 :** Cadre pour l'appréciation et le traitement des risques de sécurité de l'information.
- **EBIOS Risk Manager :** Méthode d'analyse de risque recommandée par l'ANSSI.

Attaques par Injection de Code

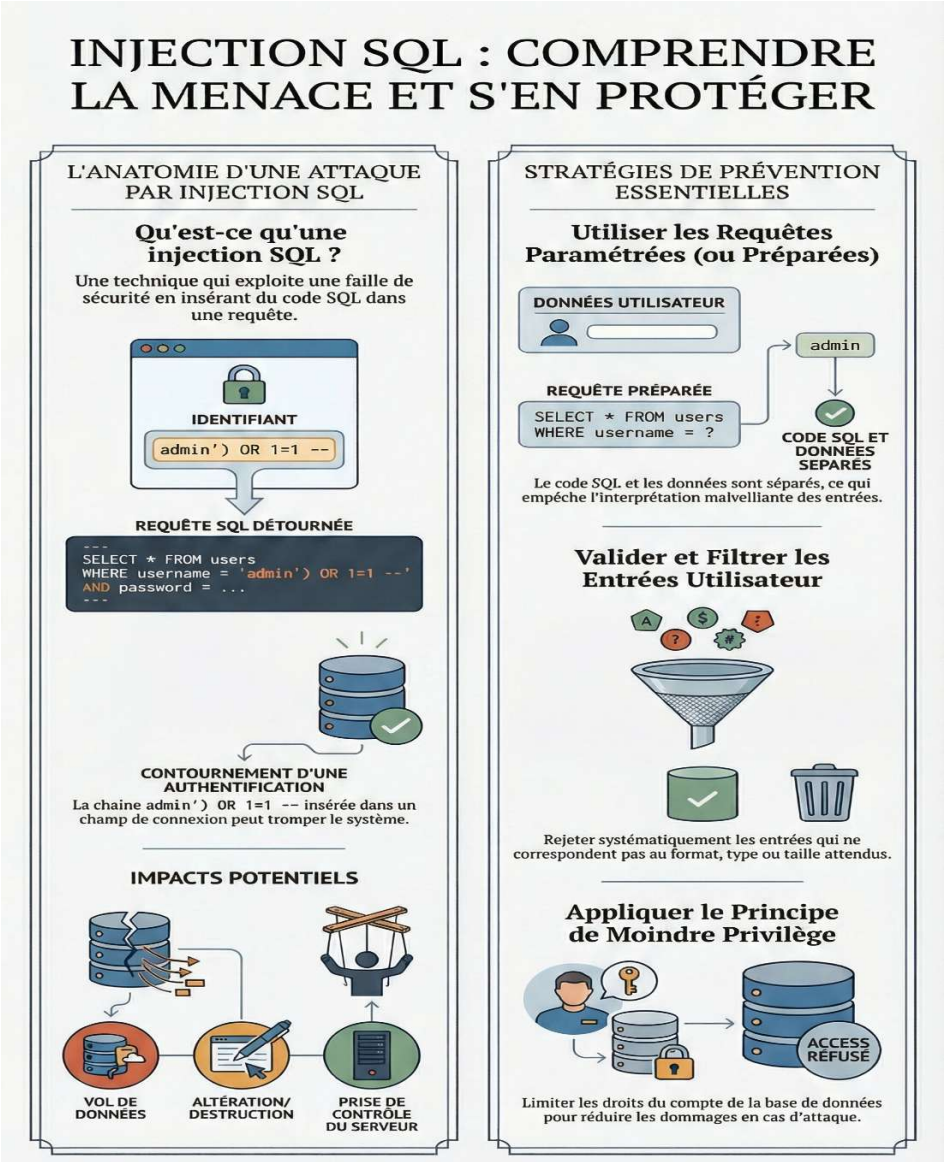
L'injection de code est une technique qui consiste à insérer des données malveillantes dans une application pour en modifier le comportement. On distingue principalement les injections côté client (navigateur web) et les injections côté serveur (base de données), souvent réalisées via les formulaires des applications.

Injection SQL (SQLi)

Une injection SQL exploite les vulnérabilités d'un site web dépendant d'une base de données. L'attaquant insère une requête SQL malveillante dans une commande envoyée par le client au serveur, qui est ensuite exécutée par la base de données.

Objectifs de l'attaque :

- **Récupération d'informations :** Obtenir des données sur le type de base de données et les requêtes exécutées.
- **Vol de données sensibles :** Extraire des informations confidentielles de l'application.
- **Contournement de l'authentification :** Outrepasser les systèmes de connexion ou modifier les autorisations d'accès.
- **Modification ou suppression de données :** Altérer ou détruire les informations stockées.
- **Indisponibilité de l'application :** Rendre l'application inaccessible en agissant sur la base de données.



Types d'attaques SQLi

Type d'Attaque	Principe	Exemple de code injecté
Tautologie	Contourner une authentification en injectant une condition toujours vraie.	login = ' OR 1=1 --
Requêtes d'Union	Combiner les résultats d'une requête légitime avec ceux d'une table différente.	login = '' UNION SELECT account_number from Bank_account --
Requêtes Multiples	Exécuter plusieurs requêtes SQL en une seule chaîne en utilisant le séparateur ;.	login = ''; DROP TABLE Users --
Attaque en Aveugle	Poser des questions Vrai/Faux à la base de données lorsque l'application ne renvoie pas d'erreurs, en déduisant les informations bit par bit.	login = ' OR 1=1 -- (pour tester la vulnérabilité)
Changement d'Encodage	Contourner les filtres en utilisant des représentations alternatives de caractères, comme la fonction CHAR().	Utiliser CHAR(45,45) pour représenter le commentaire --.

Prévention des Injections SQL

1. **Requêtes Paramétrées (ou Préparées) :** C'est la défense la plus robuste. Elle consiste à séparer la structure de la requête SQL (le code) des données fournies par l'utilisateur (les paramètres). De cette manière, le SGBD traite les entrées utilisateur comme des données pures et non comme du code exécutable. Cependant, leur efficacité dépend d'une utilisation correcte ; une concaténation de chaînes avant de paramétrer la requête annule la protection.
2. **Validation et Assainissement des Entrées :** Il est crucial de tester la taille, le type et le contenu des données reçues. Il faut rejeter les entrées contenant des données binaires, des séquences d'échappement ou des caractères de commentaire, et n'accepter que les valeurs attendues (liste blanche).
3. **Échappement des Caractères :** Des fonctions comme QUOTENAME() ou REPLACE() dans Transact-SQL peuvent être utilisées pour encadrer les entrées utilisateur avec des délimiteurs appropriés, neutralisant ainsi les caractères spéciaux.
4. **Pare-feu d'Application Web (WAF) :** Un WAF peut filtrer les requêtes SQL malveillantes en se basant sur une liste de signatures de menaces connues, agissant comme une couche de défense supplémentaire.

Cross-Site Scripting (XSS)

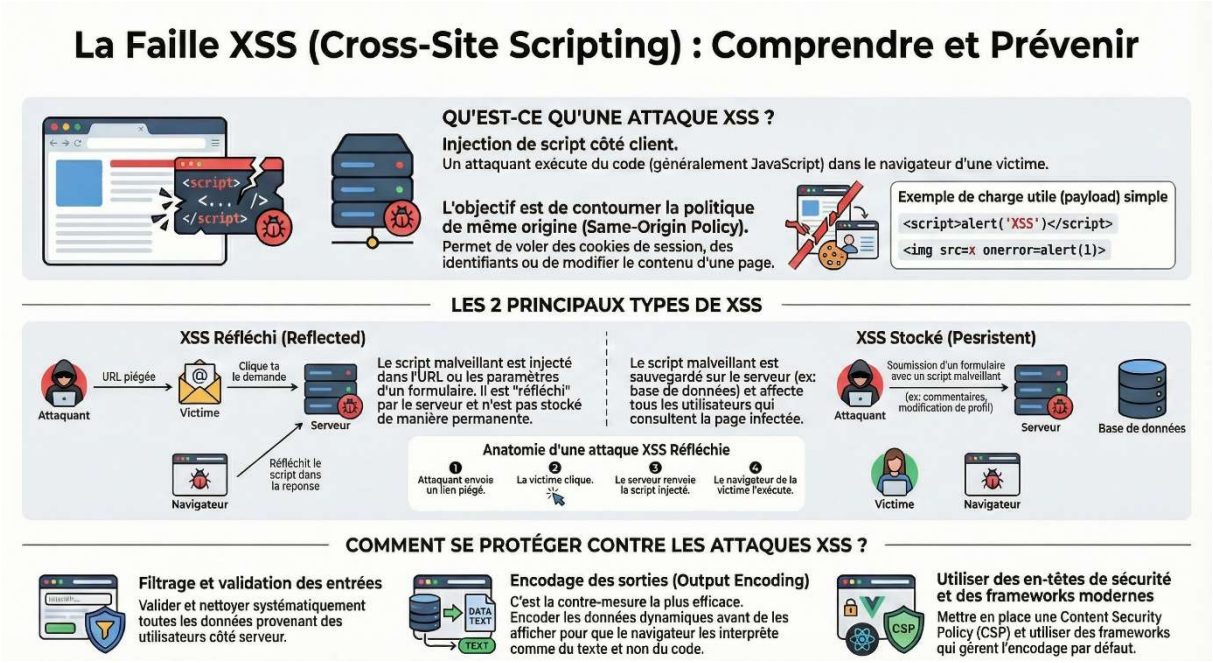
Le Cross-Site Scripting est une attaque qui injecte des scripts (généralement du JavaScript) dans la réponse d'une application web, qui sera ensuite interprétée par le navigateur de la victime. Contrairement à l'injection SQL qui cible le serveur, le XSS cible les utilisateurs de l'application.

Objectifs de l'attaque :

- Voler des données sensibles (cookies de session, informations personnelles).
- Manipuler le contenu de la page pour tromper l'utilisateur.
- Rediriger l'utilisateur vers un site malveillant.

Types d'attaques XSS

1. **XSS Réfléchi (Reflected XSS / Type 1) :** Le script malveillant est envoyé au serveur via une requête (souvent dans l'URL) et est immédiatement "réfléchi" dans la réponse HTML. L'attaque nécessite que la victime clique sur un lien forgé par l'attaquant.
2. **XSS Stocké (Stored XSS / Type 2) :** La charge utile malveillante est persistée sur le serveur (par exemple, dans un commentaire de blog, un message de forum ou un profil utilisateur). Chaque fois qu'un utilisateur consulte la page contenant cette charge, le script est exécuté. C'est le type de XSS le plus dangereux car il affecte tous les visiteurs.
3. **Heap Spraying :** Une technique plus complexe qui utilise la mémoire (le "tas") d'une application pour exécuter du code malveillant. Elle est particulièrement efficace dans les applications web où les cibles sont nombreuses.



Prévention des attaques XSS

Une approche de défense en profondeur est nécessaire pour éliminer les vulnérabilités XSS.

- **Valider les entrées utilisateur :** Toujours valider les entrées en utilisant des **listes blanches** (définir ce qui est autorisé) plutôt que des listes noires (tenter de bloquer ce qui est malveillant).

- **Appliquer un encodage de sortie contextuel :** Transformer les données utilisateur dans un format sûr avant de les afficher. Le type d'encodage dépend du contexte :
    - **Contexte HTML :** Encoder les caractères spéciaux en entités HTML (ex: < devient <).
    - **Contexte JavaScript :** Utiliser l'encodage hexadécimal pour les données insérées dans des scripts.
    - **Contexte CSS et URL :** Utiliser des encodages spécifiques pour éviter l'injection de code dans les styles ou les liens.
- **Assainir le contenu HTML enrichi :** Pour les applications qui doivent accepter du HTML de la part des utilisateurs (éditeurs de texte riche), l'encodage simple n'est pas suffisant. Il faut utiliser une bibliothèque d'assainissement robuste comme **DOMPurify** pour supprimer tout code potentiellement dangereux tout en préservant le formatage légitime.
- **Mettre en œuvre une Politique de Sécurité de Contenu (Content Security Policy - CSP) :** Utiliser des en-têtes HTTP pour indiquer au navigateur quelles sources de contenu (scripts, styles, images) sont autorisées. Une CSP bien configurée peut bloquer l'exécution de scripts injectés.
- **Adopter une approche "Secure by Design" :** Comme le soulignent la CISA et le FBI, les fabricants de logiciels ont la responsabilité d'éliminer ces défauts dès la conception, en utilisant des frameworks modernes qui offrent des protections par défaut et en effectuant des revues de code rigoureuses.

Cross-Site Request Forgery (CSRF)

La falsification de requêtes intersites est une attaque qui force le navigateur d'un utilisateur authentifié à soumettre une requête à une application web vulnérable, exécutant ainsi une action non désirée (par exemple, changer un mot de passe, effectuer un virement, etc.). L'attaque exploite le fait que le navigateur envoie automatiquement les cookies d'authentification avec chaque requête vers le domaine concerné.

Mécanismes de Défense

1. **Jetons Anti-CSRF (Tokens) :** Le serveur génère un jeton unique et imprévisible et l'associe à la session de l'utilisateur. Ce jeton doit être inclus dans chaque requête qui modifie l'état de l'application (ex: POST, PUT, DELETE). Le serveur valide ce jeton avant d'exécuter la requête.
2. **Attribut de Cookie SameSite :** Ce mécanisme de sécurité du navigateur détermine si les cookies d'un site doivent être inclus dans les requêtes provenant d'autres sites.
    - Strict : Le cookie n'est envoyé que pour les requêtes provenant du même site.
    - Lax : Le cookie est envoyé lors de la navigation de premier niveau (clic sur un lien) mais pas pour les requêtes initiées par des tiers (ex: images, iframes, requêtes POST). C'est le comportement par défaut de navigateurs comme Chrome depuis 2021.
    - None : Le cookie est envoyé avec toutes les requêtes, mais doit obligatoirement être accompagné de l'attribut Secure (HTTPS).
3. **Vérification de l'en-tête Referer :** Le serveur peut vérifier que la requête provient d'une page de son propre domaine en inspectant l'en-tête Referer. Cette méthode est moins fiable car l'en-tête peut être absent ou falsifié.

Contournements et Faiblesses des Défenses

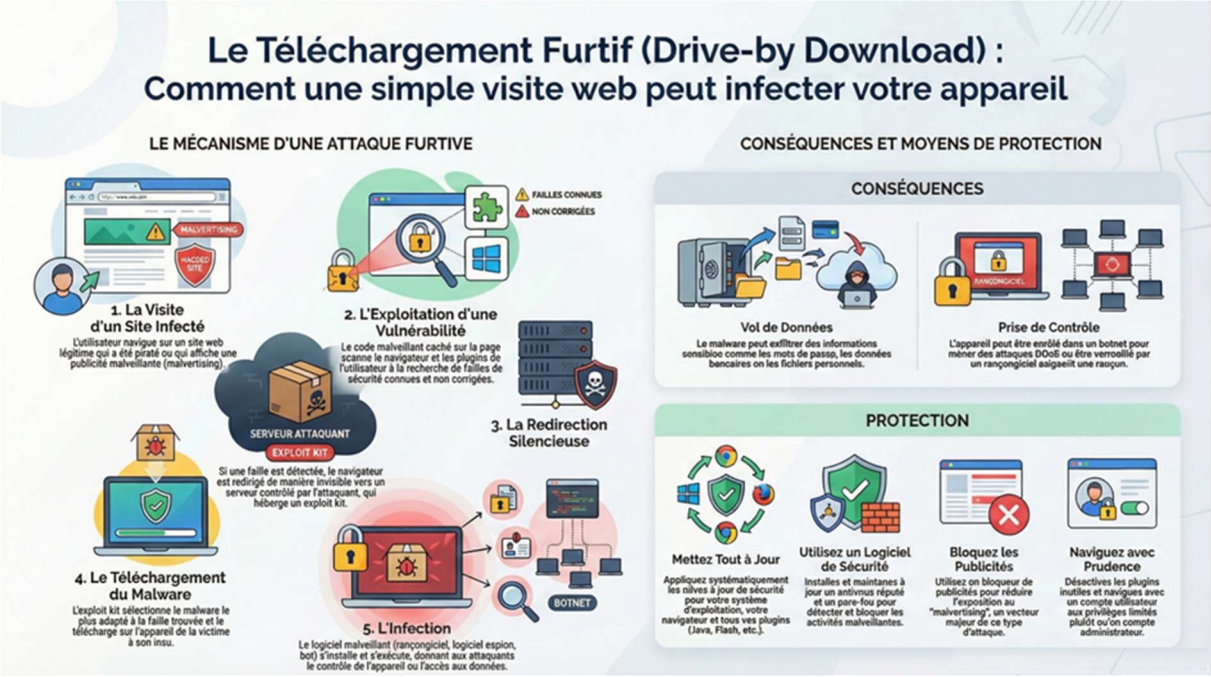
- **Failles des Jetons :** La protection par jeton peut échouer si le jeton n'est pas correctement lié à la session de l'utilisateur, s'il est réutilisé entre plusieurs requêtes (vulnérable aux attaques par rejeu), ou si la validation ne dépend pas de la méthode de la requête.
- Contournement de SameSite=Lax :
    - **Utilisation de requêtes GET :** Si une action sensible peut être déclenchée par une requête GET, un simple lien (<a href>) suffit pour contourner la protection Lax.
    - **Fenêtre de 2 minutes :** Chrome n'applique pas les restrictions Lax pour les cookies qui ont été émis il y a moins de deux minutes, afin de ne pas casser certains flux d'authentification (comme le SSO). Un attaquant peut exploiter cette fenêtre.
    - **Domaines frères vulnérables :** La restriction SameSite protège contre les requêtes inter-*sites*, mais pas inter-*origines* sur le même site. Par exemple, si marketing.example.com est vulnérable au XSS, il peut être utilisé pour lancer une attaque CSRF contre app.example.com.
- **Documentation et Configuration par Défaut :** Une étude sur 44 frameworks web populaires a révélé 157 risques de sécurité liés au CSRF. Souvent, la documentation est incomplète, les configurations par défaut sont non sécurisées et il y a une divergence d'attentes entre les développeurs de frameworks et les développeurs d'applications sur la responsabilité de la sécurisation.

Attaques par Téléchargement Furtif et Point d'Eau

Ces attaques représentent des méthodes sophistiquées pour distribuer des logiciels malveillants en exploitant la confiance des utilisateurs dans des sites web légitimes.

Drive-by Download

Le téléchargement furtif (ou "à la dérobée") est une attaque où un logiciel malveillant est téléchargé et installé sur l'ordinateur d'un utilisateur sans son consentement. La simple visite d'un site web compromis peut déclencher l'attaque. L'attaquant exploite généralement des vulnérabilités dans le navigateur, les plugins ou le système d'exploitation de la victime pour exécuter le code malveillant. Ces attaques sont souvent distribuées via des "Web Exploitation Kits" disponibles sur le darknet.



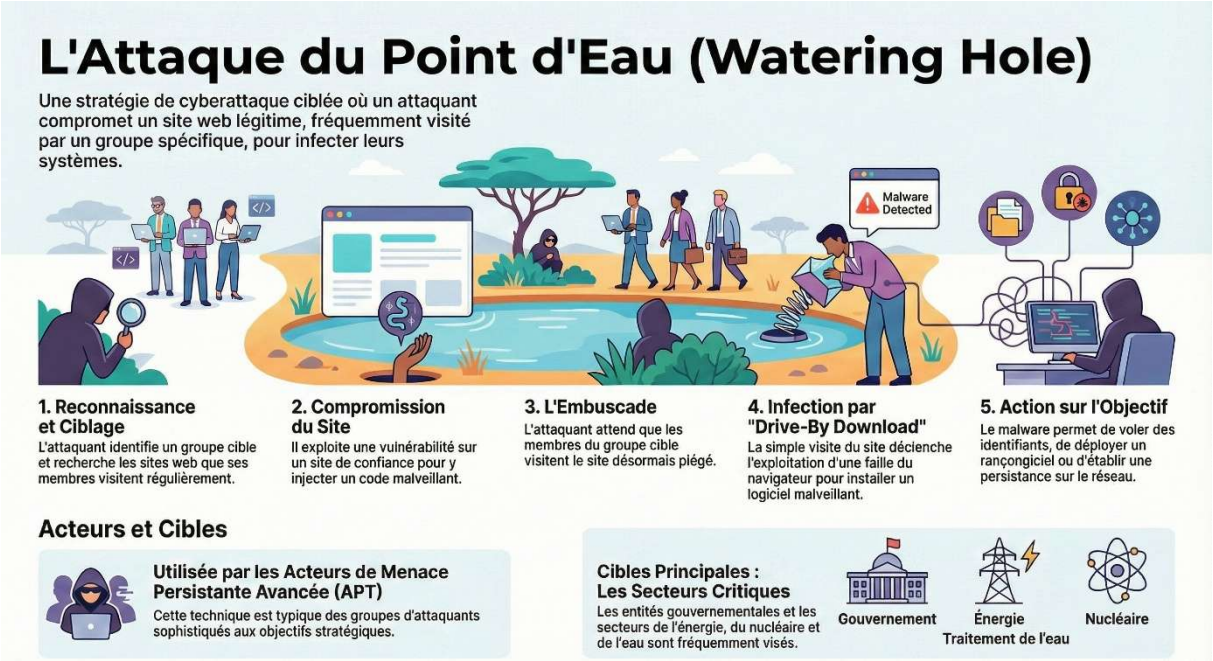
Attaque du Point d'Eau (Watering Hole)

L'attaque du point d'eau est une forme ciblée de l'ingénierie sociale qui s'appuie sur la technique du téléchargement furtif. L'attaquant ne vise pas un large public, mais un groupe spécifique d'individus ou une organisation.

Mode opératoire :

1. **Reconnaissance :** L'attaquant identifie les sites web que ses cibles visitent fréquemment (le "point d'eau").
2. **Compromission :** Il infecte un ou plusieurs de ces sites avec un code malveillant.
3. **Attente :** L'attaquant attend que les victimes visitent le site compromis, déclenchant ainsi le téléchargement du malware.

Cette technique est particulièrement efficace car elle exploite les habitudes de navigation des cibles et contourne les mesures de sécurité périmétriques en utilisant des sites de confiance comme vecteurs d'infection.



Voici une proposition de cours sur le **Spoofing** (usurpation), structuré pour des étudiants en master informatique et sécurité. Ce cours couvre les définitions techniques, les différents vecteurs (couches réseau, applicative, physique) et les stratégies de défense, basé sur les documents fournis.

Attaques par Usurpation (Spoofing)

Définition et Concepts Fondamentaux

Définition du Spoofing

Le **spoofing** (usurpation) est une situation dans laquelle une personne ou un programme s'identifie avec succès comme une autre entité en falsifiant des données pour obtenir un avantage illégitime. Contrairement au phishing qui utilise l'ingénierie sociale pour voler des données, le spoofing est une technique de falsification d'identité (numéro de téléphone, adresse e-mail, adresse IP, etc.) pour tromper un système ou un utilisateur.

De nombreux protocoles de la suite TCP/IP ne fournissent pas de mécanismes natifs pour authentifier la source ou la destination d'un message, ce qui les rend vulnérables.

Usurpation au niveau Réseau (Couches 2 et 3)

ARP Spoofing (Empoisonnement ARP)

Cette attaque cible les réseaux locaux (LAN). Le protocole ARP (Address Resolution Protocol) permet de lier une adresse IP à une adresse MAC physique, mais il ne dispose pas de mécanisme de sécurité natif et ne vérifie pas l'authenticité des réponses.

- **Mécanisme :** L'attaquant envoie des messages ARP falsifiés (souvent des réponses non sollicitées appelées "Gratuitous ARP") pour associer son adresse MAC à l'adresse IP d'une victime (souvent la passerelle par défaut) dans le cache ARP des autres machines.
- **Conséquences :** Cela permet à l'attaquant de se placer en position de "Man-in-the-Middle" (MitM). Il peut alors intercepter, modifier ou bloquer le trafic (déni de service).
- **Détection et Prévention :**
    - Utiliser l'inspection ARP dynamique (DAI) sur les commutateurs pour rejeter les paquets ARP invalides.
    - Configurer des entrées ARP statiques pour les équipements critiques (bien que difficile à maintenir à grande échelle).
    - Surveiller le trafic pour détecter des anomalies comme plusieurs adresses MAC pour une même IP.

IP Spoofing

L'usurpation d'adresse IP consiste à créer des paquets IP avec une adresse source modifiée pour dissimuler l'identité de l'expéditeur ou pour impersonifier un autre système informatique.

- **Usage dans les attaques DDoS :** L'IP spoofing est crucial pour les attaques par réflexion/amplification (ex: DNS amplification). L'attaquant envoie une requête à un serveur tiers (réflecteur) en usurpant l'IP de la victime. La réponse, souvent plus volumineuse, est envoyée à la victime, submergeant sa bande passante.
- **Contre-mesures :**
  - Filtrage des paquets (Ingress/Egress filtering) pour bloquer le trafic sortant qui ne correspond pas aux adresses IP attribuées au réseau.
  - Mise en œuvre de la norme BCP38 (Best Current Practice) par les FAI pour vérifier les adresses IP sources.

Usurpation au niveau Infrastructure et Service

DNS Spoofing (Empoisonnement de cache)

Le DNS (Domain Name System) traduit les noms de domaine en adresses IP. L'usurpation DNS vise à introduire de fausses informations dans le cache d'un résolveur DNS.

- **Mécanisme :** L'attaquant injecte des enregistrements DNS frauduleux, associant un nom de domaine légitime à une adresse IP malveillante. Lorsque les utilisateurs tentent d'accéder au site, ils sont redirigés vers un site contrôlé par l'attaquant.
- **Risques :** Redirection vers des sites de phishing, interception de données sensibles ou distribution de malwares.
- **Défense :** Le déploiement de **DNSSEC** (DNS Security Extensions) permet de signer cryptographiquement les réponses DNS pour garantir leur authenticité et leur intégrité.

Email Spoofing

Le protocole SMTP (Simple Mail Transfer Protocol) ne requiert pas d'authentification native pour l'envoi, permettant aux attaquants de modifier facilement les champs "De" (From).

- **Techniques :**
  - **Usurpation du domaine :** L'email semble provenir d'un domaine légitime (ex: @votrebanque.com).
  - **Usurpation du nom d'affichage :** Seul le nom visible est falsifié (ex: "Directeur Général" attaquant@gmail.com), technique efficace sur mobile où l'adresse réelle est souvent masquée.
  - **Domaines similaires (Typosquatting) :** Utilisation de domaines visuellement proches (ex: @amaz0n.com).
- **Protections (Authentification des emails) :**
  - **SPF (Sender Policy Framework) :** Liste les adresses IP autorisées à envoyer des emails pour un domaine.

- **DKIM (DomainKeys Identified Mail) :** Signe cryptographiquement les emails pour assurer qu'ils n'ont pas été altérés.
- **DMARC :** Utilise SPF et DKIM pour donner des instructions au serveur de réception sur la façon de traiter les emails non authentifiés (rejet, quarantaine).

Usurpation Physique et Télécoms

GPS/GNSS Spoofing

Cette attaque vise les systèmes de géolocalisation. L'attaquant émet de faux signaux GNSS plus puissants que les signaux satellites réels pour tromper le récepteur d'une cible (drone, navire, robot) sur sa position ou l'heure.

- **Cas d'usage :** Détournement de drones, perturbation de la navigation maritime, ou leurrage de jeux basés sur la localisation (comme Pokémon GO).
- **Contre-mesures :** Utilisation de logiciels anti-usurpation capables de détecter les incohérences de signal, ou l'utilisation d'antennes spéciales pour détecter la direction du signal. Pour les robots critiques, ne jamais se reposer sur une seule source de positionnement (fusion de capteurs avec compas, accéléromètres).

Caller ID Spoofing (Téléphonie)

Technique permettant d'afficher un numéro de téléphone falsifié sur l'appareil du destinataire pour gagner sa confiance (ex: afficher le numéro de la banque). En France, la **loi Naegelen** et le Mécanisme d'Authentification des Numéros (MAN) imposent désormais aux opérateurs de vérifier l'authenticité des numéros pour lutter contre cette pratique.

Conclusion

L'usurpation (spoofing) exploite souvent l'absence d'authentification dans les protocoles fondamentaux (IP, ARP, SMTP). La défense repose sur une approche en profondeur :

1. **Au niveau réseau :** Filtrage strict et inspection dynamique (DAI).
2. **Au niveau applicatif :** Implémentation rigoureuse de protocoles d'authentification (DNSSEC, DMARC/SPF/DKIM).
3. **Au niveau physique :** Redondance des capteurs et analyse du signal.

Les Attaques par Déni de Service Distribué (DDoS) : Mécanismes, Impacts et Défenses

Introduction

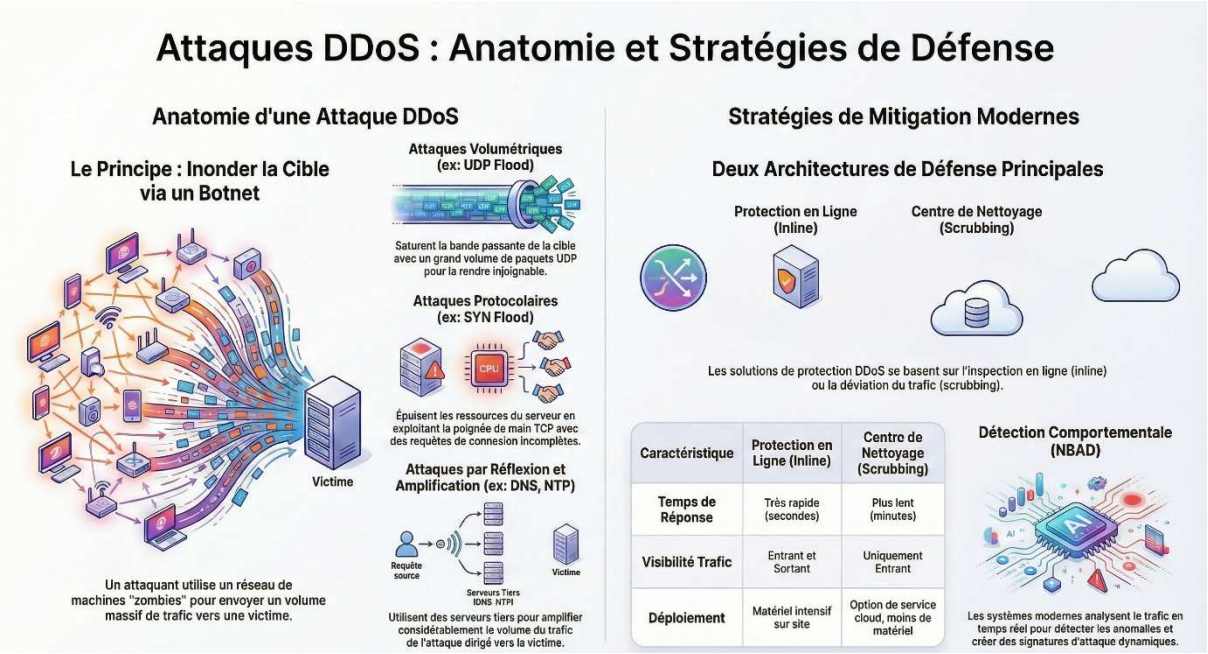
C’est un phénomène aussi disruptif que répandu dans l'écosystème numérique : les attaques par déni de service distribué, ou DDoS. Leur principe, bien que simple en apparence, cache une complexité et une puissance de nuisance redoutables.

Une attaque par Déni de Service Distribué (DDoS) est une tentative malveillante de perturber le trafic normal d'un serveur, d'un service ou d'un réseau ciblé en submergeant la cible ou son infrastructure environnante d'un flot de trafic Internet. L'objectif est de rendre un service en ligne indisponible pour ses utilisateurs légitimes.

La menace DDoS n'est pas nouvelle, mais son ampleur a atteint des niveaux sans précédent. Les statistiques récentes illustrent une escalade spectaculaire :

- Au premier trimestre 2025, Cloudflare a bloqué **20,5 millions d'attaques DDoS**, ce qui représente 96 % du volume total bloqué sur toute l'année 2024.
- Cette nouvelle norme des attaques "hyper-volumétriques", illustrée par la mitigation d'une attaque de **7,3 Tbps** en mai 2025, ne représente plus une anomalie mais une réalité opérationnelle que les infrastructures modernes doivent être capables d'absorber.

Face à cette industrialisation de la cybercriminalité, il est impératif pour de futurs professionnels comme vous de maîtriser l'anatomie de ces attaques afin de pouvoir concevoir des stratégies de défense efficaces. Analysons donc en détail leurs mécanismes.



Anatomie d'une Attaque DDoS

Pour comprendre comment se défendre, il faut d'abord disséquer la manière dont une attaque DDoS est orchestrée et exécutée. Au cœur de la majorité de ces opérations se trouve un outil redoutable : le botnet.

Classification des Attaques DDoS

Selon l'Agence pour la cybersécurité et la sécurité des infrastructures (CISA) américaine, les attaques DDoS se répartissent en trois grandes catégories.

1. **Attaques Volumétriques (Couches 3/4) :** Leur objectif est de saturer la bande passante du réseau de la cible en envoyant un volume de trafic supérieur à ce que le circuit peut supporter. Cela crée un "embouteillage" massif qui empêche le trafic légitime de passer. Les inondations de paquets ICMP (ICMP floods) en sont un exemple classique.

2. **Attaques par Protocole (Couches 3/4) :** Ces attaques visent à épuiser les ressources des équipements réseau intermédiaires, comme les pare-feu ou les répartiteurs de charge. Elles exploitent les faiblesses des protocoles des couches 3 et 4. Un exemple typique est l'exploitation de la séquence de connexion TCP : en envoyant une inondation de paquets SYN sans jamais compléter la poignée de main, l'attaquant force le serveur à allouer des ressources pour des milliers de connexions semi-ouvertes, épuisant ainsi rapidement sa table d'état.

3. **Attaques Applicatives (Couche 7) :** Plus sophistiquées, elles ciblent directement les applications et les services. Alors qu'une attaque volumétrique est une inondation de paquets bruts, une attaque de couche 7 est une inondation de transactions d'apparence légitime (ex: des millions de tentatives de connexion ou d'appels API). En utilisant des protocoles comme HTTP, elles cherchent à épuiser les ressources du serveur applicatif (CPU, mémoire). Leur danger réside dans leur caractère furtif : elles imitent le comportement d'utilisateurs réels, rendant leur détection très difficile sans inspection approfondie des paquets ou analyse comportementale. Les attaques "lentes" (comme le *slow HTTP post*), qui envoient des requêtes HTTP morcelées très lentement pour maintenir les connexions ouvertes, appartiennent à cette catégorie.

Une des techniques les plus puissantes et les plus courantes aujourd'hui combine des éléments de ces catégories : l'attaque par réflexion et amplification.

Focus sur les Attaques par Réflexion et Amplification (DRDoS)

Une attaque par réflexion et amplification distribuée (DRDoS) est une méthode particulièrement efficace pour générer des volumes de trafic colossaux avec des ressources limitées. Le mécanisme se déroule en deux temps :

1. L'attaquant **usurpe (spoof)** l'adresse IP source de ses paquets, en la remplaçant par celle de sa victime.

2. Il envoie ensuite de petites requêtes à un grand nombre de serveurs tiers mal configurés et accessibles sur Internet (DNS, NTP, Memcached, etc.), que l'on nomme **"amplificateurs"**. Ces serveurs, croyant répondre à la victime, lui envoient des réponses massivement plus volumineuses que les requêtes initiales.

Cette technique permet d'anonymiser l'attaque et de multiplier sa puissance de manière exponentielle.

- **Attaque de 2018 contre GitHub :** Cette attaque historique a atteint un pic de **1,35 Tbps**. Elle a utilisé comme amplificateurs des serveurs **Memcached** mal configurés, qui offrent un facteur d'amplification pouvant aller jusqu'à **51 000 fois** la taille de la requête initiale.
- **Attaque de 2020 contre AWS :** Amazon a mitigé une attaque de **2,3 Tbps** qui exploitait des serveurs **CLAP** (Connection-less Lightweight Directory Access Protocol) comme réflecteurs.

Maintenant que nous comprenons le "comment", penchons-nous sur le "qui" et le "pourquoi".

2. Acteurs, Motivations et Économie des DDoS

Les motivations derrière une attaque DDoS sont aussi variées que les acteurs qui les lancent.

Profils des Attaquants et Motivations

Profil de l'Attaquant	Motivation Principale
Cybercriminels	Gain financier direct via le rançonnage (**Ransom DDoS - RDDoS**).
Activistes (Hacktivistes)	Déni de service pour une cause idéologique ou politique, déstabilisation.
Gouvernements Hostiles	Espionnage, sabotage, ou déstabilisation dans le cadre d'opérations de cyberguerre.
Concurrents / Particuliers	Perturbation des services d'un rival ou chantage.

Il est crucial de comprendre qu'une attaque DDoS peut servir d'**écran de fumée**. Pendant que les équipes de sécurité sont mobilisées pour restaurer la disponibilité du service, l'attaquant peut mener en parallèle une opération plus ciblée et plus lucrative, telle qu'une exfiltration de données sensibles ou le déploiement d'un rançongiciel, transformant une attaque de disponibilité en une brèche de confidentialité.

L'accès à ces capacités d'attaque s'est malheureusement largement démocratisé.

2.2. La Démocratisation des Attaques

Le modèle économique des **"DDoS-as-a-Service"** a rendu ces attaques accessibles à tous. Sur le Darknet, des plateformes permettent de louer la puissance de botnets pour lancer des attaques ciblées.

Il est aujourd'hui possible d'acheter une attaque pour seulement **100 $**, ce qui abaisse considérablement la barrière à l'entrée technique et financière pour des acteurs malveillants.

Cette facilité d'accès, couplée à la puissance des attaques, a des conséquences concrètes et coûteuses pour les entreprises victimes.

Impacts et Conséquences d'une Attaque DDoS

Une attaque DDoS réussie ne se limite pas à une simple interruption de service. Les dommages sont multiples et peuvent affecter l'entreprise à court, moyen et long terme.

- **Impact Financier Direct :** Une interruption de service coûte en moyenne **40 000 $ par heure**. Pour 51 % des entreprises touchées, une attaque DDoS entraîne une réduction directe des revenus, un chiffre qui ne capture pas l'ensemble des pertes économiques indirectes.
- **Impact Opérationnel :** L'impact ne se limite pas à l'infrastructure. Les équipes opérationnelles sont submergées : les services clients font face à un afflux de requêtes d'utilisateurs frustrés, tandis que les équipes techniques, en pleine gestion de crise, deviennent aveugles à d'autres menaces potentielles.
- **Impact sur la Réputation :** Plus insidieuse que la perte financière directe est l'érosion du capital confiance. Pour 43 % des organisations, la conséquence la plus dommageable est la perte de confiance des consommateurs. Dans notre économie numérique, la réputation n'est pas un actif secondaire ; elle est le fondement de la relation client.
- **Coûts de Remédiation :** Après l'attaque, les coûts continuent de s'accumuler. 52 % des entreprises doivent remplacer des logiciels ou du matériel. S'ajoutent à cela les honoraires potentiels de consultants externes pour analyser l'incident et renforcer les défenses.

Face à de tels risques, comment une organisation peut-elle se protéger efficacement ?

Stratégies de Mitigation et de Défense

La protection contre les DDoS modernes ne peut reposer sur des solutions de sécurité traditionnelles. Elle exige une approche spécialisée et une architecture de défense pensée en profondeur.

Les Limites des Défenses Traditionnelles

Les pare-feux et les systèmes de prévention d'intrusion (IPS) classiques, bien qu'essentiels pour la sécurité périmétrique, sont souvent les premières victimes d'une attaque DDoS volumétrique. Voici pourquoi :

- **Épuisement de la table de connexions :** Ces équipements maintiennent une table d'état pour suivre chaque connexion active. Le volume d'une attaque DDoS, avec ses milliers de paquets par seconde, submerge rapidement la capacité de cette table, provoquant leur propre déni de service.
- **Trafic d'apparence légitime :** Les attaques de couche 7 (comme un HTTP Flood) sont composées de millions de requêtes qui, prises individuellement, sont parfaitement valides. Un pare-feu standard est incapable de distinguer ce trafic malveillant d'un pic de trafic légitime.
- **Vulnérabilité aux attaques "lentes" :** Des attaques comme Slowloris établissent des sessions TCP et les maintiennent ouvertes en envoyant des données à un rythme extrêmement lent, sans jamais compléter la requête. Comme la connexion est établie et que peu de données sont échangées, les pare-feux et IPS n'inspectent souvent pas ce comportement et laissent passer l'attaque.

Il est donc nécessaire d'adopter une stratégie plus robuste et à plusieurs niveaux.

Une Approche de Défense en Profondeur

Une stratégie de mitigation efficace se décompose en quatre phases cycliques.

1. **Détection :** La clé d'une détection rapide est de connaître son trafic normal. Il est crucial d'établir une **ligne de base (baseline)** précise des modèles de trafic (volumes, sources, protocoles). Toute déviation significative par rapport à cette baseline peut alors déclencher une alerte.

2. **Réponse :** Une fois l'attaque détectée, le trafic suspect est dévié, via une annonce BGP, vers un centre de nettoyage (**scrubbing center**) opéré par un fournisseur spécialisé. Ce centre, doté d'une capacité de bande passante massive et d'équipements de filtrage avancés, "lave" le trafic en éliminant les paquets malveillants avant de réacheminer le trafic légitime vers l'infrastructure de la cible.

3. **Filtrage :** Les centres de nettoyage utilisent diverses techniques pour distinguer les attaquants des vrais utilisateurs. Celles-ci incluent la **limitation de débit (Rate Limiting)** par adresse IP, le blocage de sources non autorisées via des listes de contrôle d'accès (ACL), et des défis cryptographiques pour les requêtes suspectes.

4. **Analyse :** Après l'incident, une analyse forensique est essentielle pour comprendre le ou les vecteurs d'attaque utilisés, identifier les vulnérabilités exploitées et ajuster la stratégie de défense pour renforcer la protection contre de futures tentatives.

Pour compléter cette approche, voici quelques bonnes pratiques fondamentales :

- **Réduire la surface d'attaque :** Masquez vos serveurs d'origine derrière un Réseau de Diffusion de Contenu (CDN) ou un répartiteur de charge. Bloquez rigoureusement tous les ports et protocoles qui ne sont pas absolument nécessaires au fonctionnement de vos services.

- **Planifier la continuité d'activité :** Assurez la redondance géographique et logique de vos systèmes critiques pour permettre un basculement en cas d'attaque réussie sur un site principal.

- **Durcir le DNS :** Limitez la récursion de vos serveurs DNS aux utilisateurs autorisés. Cette configuration simple empêche vos serveurs d'être involontairement instrumentalisés comme "amplificateurs" dans une attaque DRDoS visant un tiers.

- **Mettre en place la segmentation du réseau :** Principe fondamental, la segmentation isole les systèmes critiques dans des sous-réseaux. En cas de brèche dissimulée par une attaque DDoS, ce cloisonnement limite la capacité d'un attaquant à se déplacer latéralement et à compromettre l'ensemble de l'infrastructure.

Conclusion : L'Évolution Continue de la Menace DDoS

Cette présentation a mis en lumière trois tendances fondamentales qui définissent le paysage actuel des menaces DDoS :

- L'**augmentation exponentielle** du volume et de la fréquence des attaques, qui atteignent désormais des térabits par seconde.

- La **sophistication croissante** des vecteurs, exploitant des botnets d'objets connectés massifs et des techniques d'amplification toujours plus ingénieuses.

- La **démocratisation** de la menace, qui rend la capacité de lancer des attaques dévastatrices accessible à un coût dérisoire via les services "DDoS-as-a-Service".

Pour vous, futurs architectes et responsables de systèmes d'information, la leçon est claire. Face à une menace aussi dynamique et omniprésente, la simple protection n'est plus suffisante. La clé réside dans la construction d'une **résilience opérationnelle** : une capacité organisationnelle et technique à anticiper les attaques, à y résister tout en maintenant les services critiques, et à récupérer rapidement après un incident. Ce paradigme de résilience n'est plus une simple bonne pratique ; il est désormais au cœur de réglementations européennes exigeantes comme DORA pour le secteur financier et la directive NIS2, qui imposent des tests de résilience rigoureux, incluant des simulations d'attaques DDoS, pour toutes les entités critiques et importantes.

Définition et Architecture des Botnets

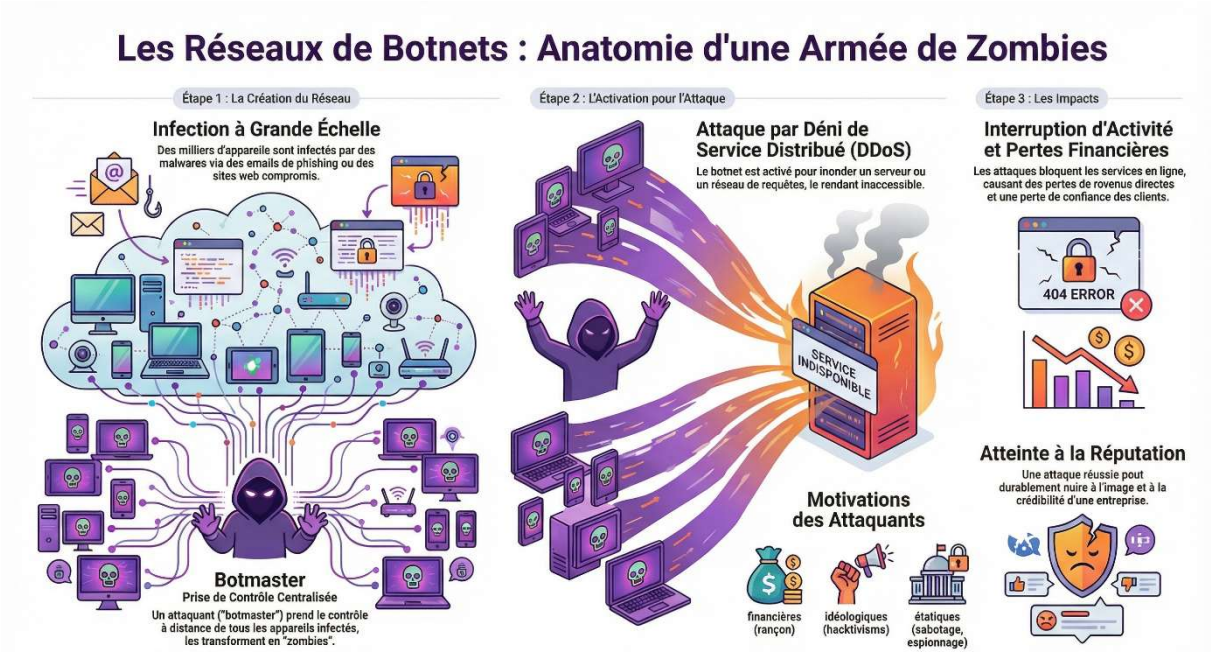
Définition

Un **botnet** (réseau de robots) est un ensemble de systèmes informatiques compromis, appelés « bots » ou « zombies », contrôlés à distance par un acteur malveillant (le « botmaster » ou « bot herder »). Les propriétaires légitimes de ces appareils ignorent généralement que leur machine participe à ce réseau.

Modèles de Commande et Contrôle (C2)

L'infrastructure C2 est le cœur du botnet, permettant au botmaster d'envoyer des instructions. On distingue deux modèles principaux :

- **Modèle Centralisé (Client-Serveur) :** Tous les bots se connectent à un serveur central pour recevoir des instructions. Ce modèle est plus simple à gérer pour l'attaquant mais présente un point de défaillance unique (Single Point of Failure) : si le serveur C2 est neutralisé, le botnet est inopérant.
- **Modèle Décentralisé (Peer-to-Peer / P2P) :** Les bots communiquent directement entre eux pour relayer les commandes. Ce modèle est beaucoup plus résilient et difficile à démanteler car il n'y a pas de serveur central unique à cibler.
    - *Exemple technique :* Le botnet **Gameover Zeus** utilise une architecture P2P complexe pour échanger des listes de pairs et des proxys, rendant sa détection difficile.
    - *Exemple technique :* Le botnet **ZeroAccess v2** utilise un échange de listes de pairs et de commandes via des charges utiles UDP spécifiques.



Techniques de dissimulation : Le Fast Flux

Pour protéger l'infrastructure C2, les attaquants utilisent des techniques comme le **Fast Flux**. Cette méthode exploite le système DNS en associant plusieurs adresses IP à un même nom de domaine et en changeant ces adresses à une fréquence très élevée (TTL très bas, souvent autour de 5 secondes). Les adresses IP utilisées sont souvent celles de machines compromises servant de relais (proxies) vers le véritable serveur du pirate.

Vecteurs d'Infection et Propagation

Vecteurs d'accès initial

Les botnets recrutent de nouveaux membres via diverses méthodes :

- **Exploitation de vulnérabilités :** Les attaquants scannent Internet pour trouver des appareils non corrigés ou mal configurés. Par exemple, le botnet Mirai cible les appareils IoT (caméras, routeurs) utilisant des mots de passe par défaut.
- **Phishing et Ingénierie Sociale :** Envoi d'emails contenant des pièces jointes malveillantes ou des liens vers des sites infectés.
- **Téléchargements "Drive-by" :** Infection via la visite d'un site web compromis.
- **Compromission de la chaîne d'approvisionnement (Supply Chain) :** Infection via des logiciels tiers ou des fournisseurs de services gérés (MSP).

Mécanismes de propagation (Scanning)

Une fois infecté, un bot peut scanner le réseau (horizontal scanning) pour identifier d'autres cibles potentielles.

- *Exemple :* Mirai effectue un scan asynchrone et sans état (stateless) en envoyant des paquets TCP SYN à des adresses IPv4 pseudo-aléatoires pour localiser des appareils IoT vulnérables via Telnet.

Étude de Cas - Le Botnet Mirai

Présentation

Découvert en 2016, Mirai est un malware ciblant les appareils Linux, principalement dans l'Internet des Objets (IoT). Il a été utilisé pour des attaques DDoS massives, notamment contre l'hébergeur OVH et le fournisseur DNS Dyn, perturbant l'accès à des services majeurs comme Twitter et Netflix.

Fonctionnement technique

1. **Infection :** Mirai scanne Internet pour trouver des appareils IoT et tente de s'y connecter via Telnet en utilisant une table interne de plus de 60 paires d'identifiants/mots de passe par défaut (ex: admin/admin, root/123456).

2. **Exécution :** Une fois connecté, il infecte l'appareil (qui continue de fonctionner mais avec une bande passante réduite) et supprime les malwares concurrents de la mémoire. Le malware est non-persistant : un redémarrage nettoie l'appareil, mais il est souvent réinfecté en quelques minutes s'il n'est pas sécurisé.
3. **Attaque :** Les appareils infectés écoutent le serveur C2 pour recevoir des ordres d'attaque.

Évolution et Variantes

Le code source de Mirai a été publié, menant à la création de nombreuses variantes :

- **Satori :** Exploite des failles zero-day dans les routeurs Huawei.
- **Okiru :** Cible les processeurs ARC (utilisés dans de nombreux appareils embarqués).
- **Wicked :** Cible des routeurs Netgear et des enregistreurs CCTV-DVR non corrigés.

Utilisation des Botnets pour les Attaques DDoS

L'une des fonctions primaires des botnets est de lancer des attaques par Déni de Service Distribué (DDoS).

Attaques Volumétriques (Couches 3/4)

Le but est de saturer la bande passante de la cible.

- **Amplification DNS :** Le botnet envoie des requêtes à des résolveurs DNS ouverts en usurpant l'adresse IP de la victime. La réponse, beaucoup plus volumineuse que la requête, est envoyée à la victime, saturant son réseau,.
- **UDP Floods :** Envoi massif de paquets UDP vers des ports aléatoires de la cible.

4.2. Attaques Protocolaires (Couches 3/4)

Le but est d'épuiser les ressources des équipements réseau (pare-feux, équilibreurs de charge).

- **SYN Flood :** Exploite le handshake TCP. Les bots envoient des paquets SYN sans jamais envoyer le ACK final. Le serveur alloue des ressources pour ces connexions semi-ouvertes jusqu'à épuisement.

4.3. Attaques Applicatives (Couche 7)

Plus furtives, elles visent à épuiser les ressources du serveur web en imitant un comportement utilisateur légitime.

- **HTTP Flood :** Les bots envoient un grand nombre de requêtes GET ou POST légitimes (ex: requêtes de recherche ou de login) pour surcharger le serveur.
- **Slowloris :** Les bots ouvrent de nombreuses connexions et les maintiennent ouvertes le plus longtemps possible en envoyant des en-têtes HTTP partiels très lentement.

Stratégies de Défense et Atténuation

Détection

- **Surveillance réseau :** Analyser les journaux (logs) et le trafic (Netflow) pour repérer des anomalies comme des volumes de trafic sortant inhabituels ou des connexions vers des serveurs C2 connus,.
- **Détection d'anomalies protocolaires :** Identifier des modèles suspects, comme une augmentation soudaine de réponses ARP non sollicitées (Gratuitous ARP) qui pourrait indiquer une attaque de type "Man-in-the-Middle" facilitée par un botnet.
- **Threat Intelligence :** Utiliser des flux de renseignements pour bloquer les IP et domaines malveillants connus.

Atténuation

- **Filtrage et "Blackholing" :** En cas d'attaque volumétrique, le trafic peut être redirigé vers un "trou noir" (null route) pour protéger le reste du réseau, bien que cela rende le service inaccessible pour la cible visée.
- **Rate Limiting :** Limiter le nombre de requêtes par adresse IP pour atténuer les attaques applicatives et protocolaires,.
- **Défense en profondeur :** Utiliser des pare-feux applicatifs (WAF) pour les attaques de couche 7 et des services de nettoyage (scrubbing centers) basés sur le cloud pour les attaques volumétriques massives.

Prévention (Hygiène Cyber)

- **Gestion des accès :** Changer les mots de passe par défaut des appareils IoT et désactiver les services non utilisés (comme Telnet sur les ports WAN).
- **Segmentation réseau :** Isoler les appareils IoT et les systèmes critiques pour empêcher la propagation latérale des infections.
- **Mises à jour :** Appliquer régulièrement les correctifs de sécurité pour combler les vulnérabilités exploitées par les variantes de botnets.

Pour approfondir vos connaissances et vous tenir informé des meilleures pratiques, voici quelques ressources officielles de référence :

- **ANSSI - Guides des bonnes pratiques :** www.ssi.gouv.fr/administration/bonnes-pratiques
- **ANSSI - MOOC SecNumAcadémie :** secnumacademie.gouv.fr
- **Plateforme gouvernementale d'assistance :** www.cybermalveillance.gouv.fr